FIT2093 Assignment 3 – Semester 1, 2024 Submission Guidelines & Tasks

Guidelines Details

- **Deadline:** Assignment 2 submission is due **in Week 15** on **10 June 2024** at 11:55pm Melbourne, Australia time (CL Campus) and **10 June 2024** at 11:55pm Malaysia time (MA Campus). This Task is an individual (not group) work and it must be submitted by each student **individually**.
- **Submission Platform:** Electronic submission via the `Assignment 2 Submission' link on the Moodle Assessments page (an Ed announcement will be sent once the link is added).
- **Required Files:** Required VM files for the assignment will be available for download via the Moodle Asg 3 Moodle Submission Link.
- **Submission File Format:** One PDF document for all 4 tasks.
- **Submission Page Limit:** The submitted PDF document must be **at most 20 pages, excluding cover page and references**. Any screenshots that cannot fit in the main 20 pages can be placed in an Appendix (which does not count in the page limit).
- **Plagiarism:** It is an academic requirement that your submitted work be original. Zero marks will be awarded for the whole submission if there is any evidence of copying, collaboration, pasting from web sites, or copying from textbooks.
- **Use of Generative AI tools:** ChatGPT or other AI tools may be used for study purposes, to learn about your topic, and to develop your assignment. However, similar to citation requirements for other references, you must include a clear declaration of all generative AI tools used (e.g. ChatGPT, DALL-E, Grammarly, voice-to-text), how and where you have used them. Please follow the Monash guidelines on how to acknowledge the use of Generative AI.

Notes

- **For each question**, you need to answer **both** the computation result question **and** the explanation questions about your working process such as the source code or the commands you are using to solve the tasks.
- Note that if numbers in this assignment are specified in hexadecimal format, your written answer and many software packages expect hexadecimal numbers to be input a '0x' prefix (e.g. '0xa0b1c2d3') for indicating the hexadecimal format. For example, this prefix allows SageMath to interpret the value in hex.

Overview of the assignment

The assignment is worth 30% of your total unit mark.

Your goal in this assignment is to do security/penetration testing of a mini web application to identify web application and SQL injection vulnerabilities in it, using the techniques covered in our Web and database security lectures. Then, the goal is to demonstrate how to exploit the vulnerabilities discovered to break the app's security. Finally, you will reflect on the invited lecture from Week 12 and on applying your unit knowledge in a daily life situation.

In **Task 1** of the assignment (weight: 10% of your unit mark), you will demonstrate your understanding of XSS security vulnerabilities by testing the web application such vulnerabilities and assessing whether any vulnerabilities you find can potentially be exploited by an attacker.

In **Task 2** of the assignment (weight: 4% of your unit mark), you will demonstrate your understanding of client-side penetration testing techniques to attempt to bypass the web application's mechanism for enforcing access control to private documents to authorised users.

Task 3 of the assignment (weight 6% of your unit mark) requires you to demonstrate your skills in testing for SQL injection vulnerabilities in a part of the web application that makes queries to an SQL database, and exploit any vulnerabilities you discover to breach gain unauthorised access to the database.

Task 4 of the assignment (weight 10% of your unit mark) requires you to write your reflection of the invited lecture in Week 12 and personal experience in relation to Cyber Security

Assessment Details

Task	Rubric
Task 1	10% ■ Task A (3%): list of potential XSS vulnerability points (2%) and explain the results (1%) ■ Task B (7%): for testing techniques (1%), tests results (2%) and send out document cookie to attacker's domain (1%) Explain the vulnerability (2%) and mitigation (1%)
Task 2	4% ■ Testing(s) techniques (2%) and ■ exploit/vulnerabilities' explanation (2%)
Task 3	6% ■ Task A (4%): for list of users testing (2%), results and interpretation, for table and fields testing results and interpretation) (2%) ■ Task B (2%): for modifying a non phone no. field testing(1%), results and interpretation (1%)
Task 4	10% ● Reflection of Invited Lecture (5%) ● Reflection of personal cyber security experience (5%)

Assignment Details

You can download the Asg3 VM file from the link in the Moodle Asg3 Submission Page:
- for Windows or Mac devices with Intel CPUs (.ova file), or
- for Mac M1/M2 devices with VMWare Fusion player (.zip file), or
- for Mac M1/M2 devices with UTM player (.qcow2 file), see Ed #222

Once you run the VM, log in with the following credential:

VM login name: student
VM password: student

Your task is to perform the following security tests on this web application. You should perform these tests using the Firefox or burpsuite built-in web browser installed in your VM, and the burpsuite tool installed in the given VM.

Task 1 (10% of unit marks): Committee Member Security Test

Visit the homepage for the web application at the URL (http://alicefansclub.org/index.php) using your web browser. If all is well, the browser should display a page that looks as in **Fig. 1**.

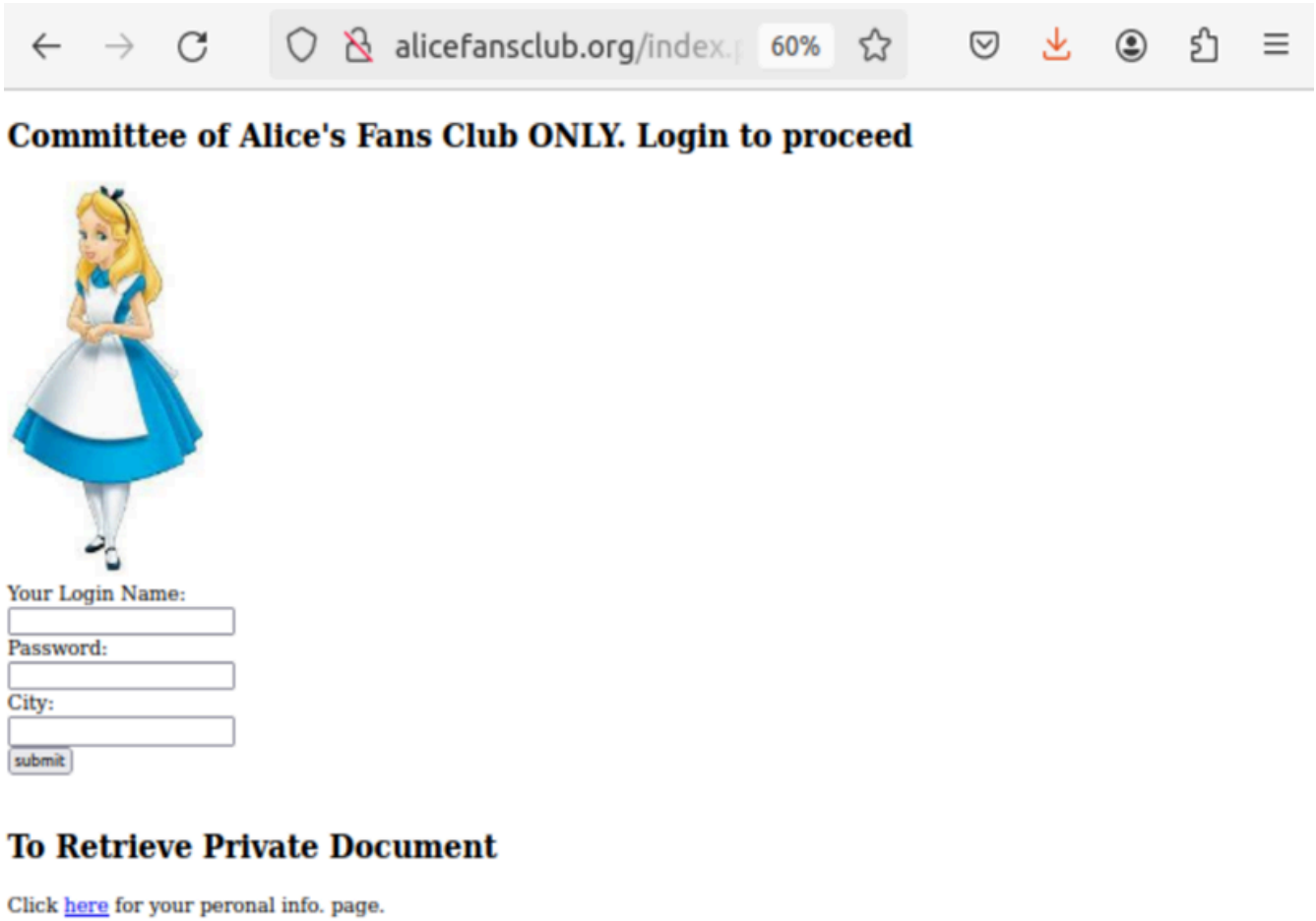


Fig.1 *Login Pag*

This web app allows committee members of Alice Fans Club to access their personal documents.

In this part, your aim is to do security testing of the **committee member** part of the web application, from the point of view of an attacker trying to reveal the secret committee information. To help you with this, you are given the login credentials of one of the registered committee members (however, note that an outsider attacker may or may **not** know credentials other than provided):

Username: Alice
Password: alice
City: Sydney

After clicking the “submit” button with the above credential, the browser should display a welcome page, as shown in **Fig. 2**.



Fig. 2. *Welcome page*

Then, after entering the event details e.g May 2024 and Sydney into the boxes and then clicking the “submit” button, you should see the show poster as shown in **Fig. 3**.



Fig. 3. *Secret report of observation.*

Complete the following tasks:

- **Task 1A (3 mark)** Based on the application behavior for login and welcome pages above:
  - Based on the behaviour of the web application pages above with an **honest** user**, list potential points** on the home and greeting pages where a **reflected XSS** input injection vulnerability **may potentially exist**. (No actual XSS attack is required in this task).
  - **Explain why** the points you listed are **potential** XSS vulnerability points.

- **Task 1B** (**7 mark)** Experiment with the home page login and welcome and member report pages in **Figs. 1-3**, and examine the behavior of these pages to different inputs. In particular:
  - For each of the **potential** XSS vulnerability points listed in Task A.1, perform tests to see if XSS vulnerabilities **actually exist** at these points.
  - Assume you set up a web application server, craft a malicious script that could allow the attacker to receive the target user's session cookie by launching an XSS attack on one of the chosen vulnerability points.
  - In the report,
    - Describe and explain your testing approach
    - Draw a table of test results and your interpretation/conclusions on why or why not such XSS vulnerability exists (**note**: you only need to test if script injection is possible, no social engineering considerations are required).
    - Screenshot of script and the feasibility of receiving cookies at the attacker's application server. (**note**: you only need to show the script and evidence for its execution to steal the cookie, no social engineering attack feasibility/demo is required)
    - Explain how to mitigate the vulnerabilities.

Task 2 (4% of unit marks): Personal Information Security Test

In this part, your aim is to do security testing of the fans' personal information part of the web app. For this, you are given one of fans' name and password, namely:

Member Name: Grace
Member ID Number: 3
Member password: Ro4mvSemq45xfepvaEr24

Use Grace's **member ID number** and **Member password** to log in to the Personal Private Information login page shown in **Fig. 4**.

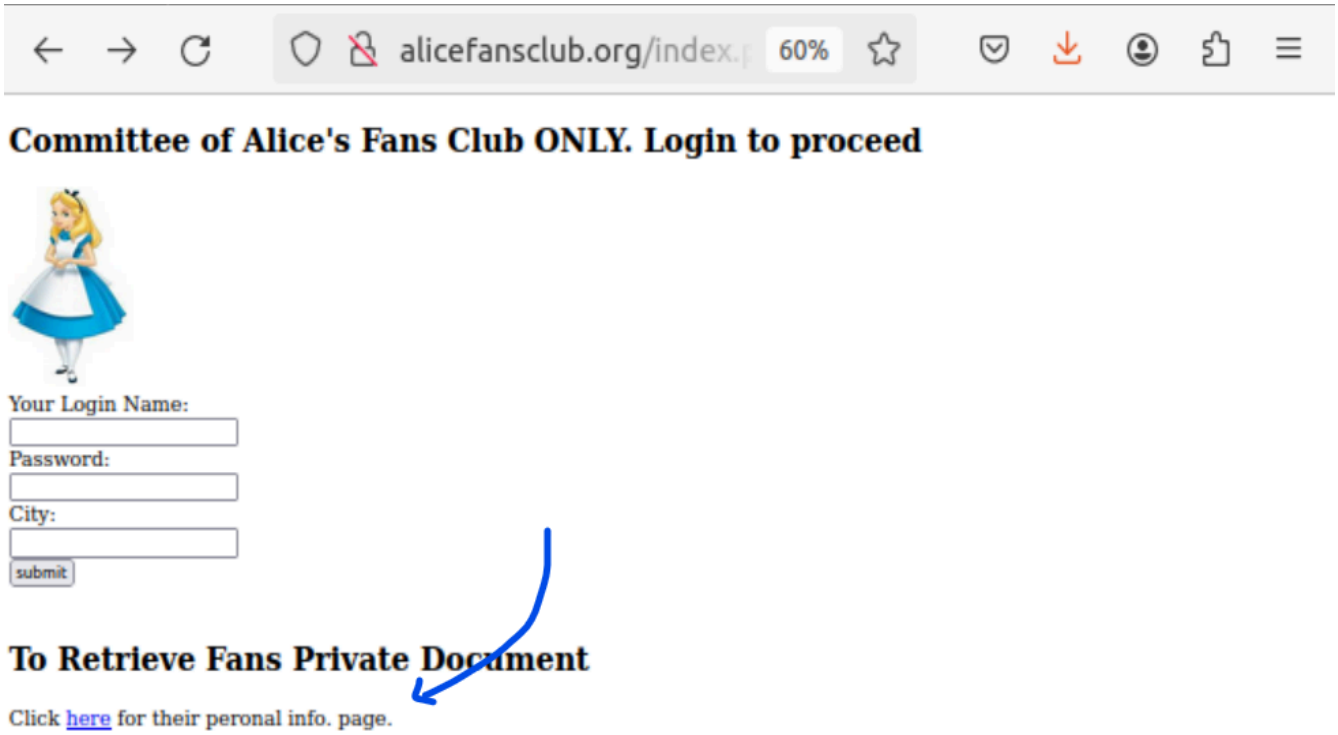


Fig. 4. *Personal Private Information login page.*

Complete the following tasks:

Grace has two private documents stored in his account with document IDs 1 and 2. Your goal in this task is to test the application against attacks by **Grace** (Member ID: 3) who is curious to learn about another member **Camy**'s **(Member ID: 4)** private information.

- Can **Grace** gain unauthorised access to **Camy**'s personal private data?
  - If you think it is possible, explain the vulnerability you found and how **Grace** can exploit it, and show any private data of **Camy** you managed to expose by the attack.
  - If you think it is not possible, explain why.

- In any case, explain the tests you did, the results, and your interpretation of them.

Hints: experiment with the personal private information part of the web app to see how it behaves with **different inputs** from **Grace**. Use the burpsuite tool (see week 10 applied session) to help with your experiments and try out potential attacks.

Task 3 (6% of unit marks): Attack on the database

In this part, your aim is to test for potential database SQL injection vulnerabilities in the committee's **personal profile** page**.** To do so, click the "here" link at the bottom of the "Welcome" page (see **Fig. 5**) after logging in as the user **Alice** as explained in Task A.

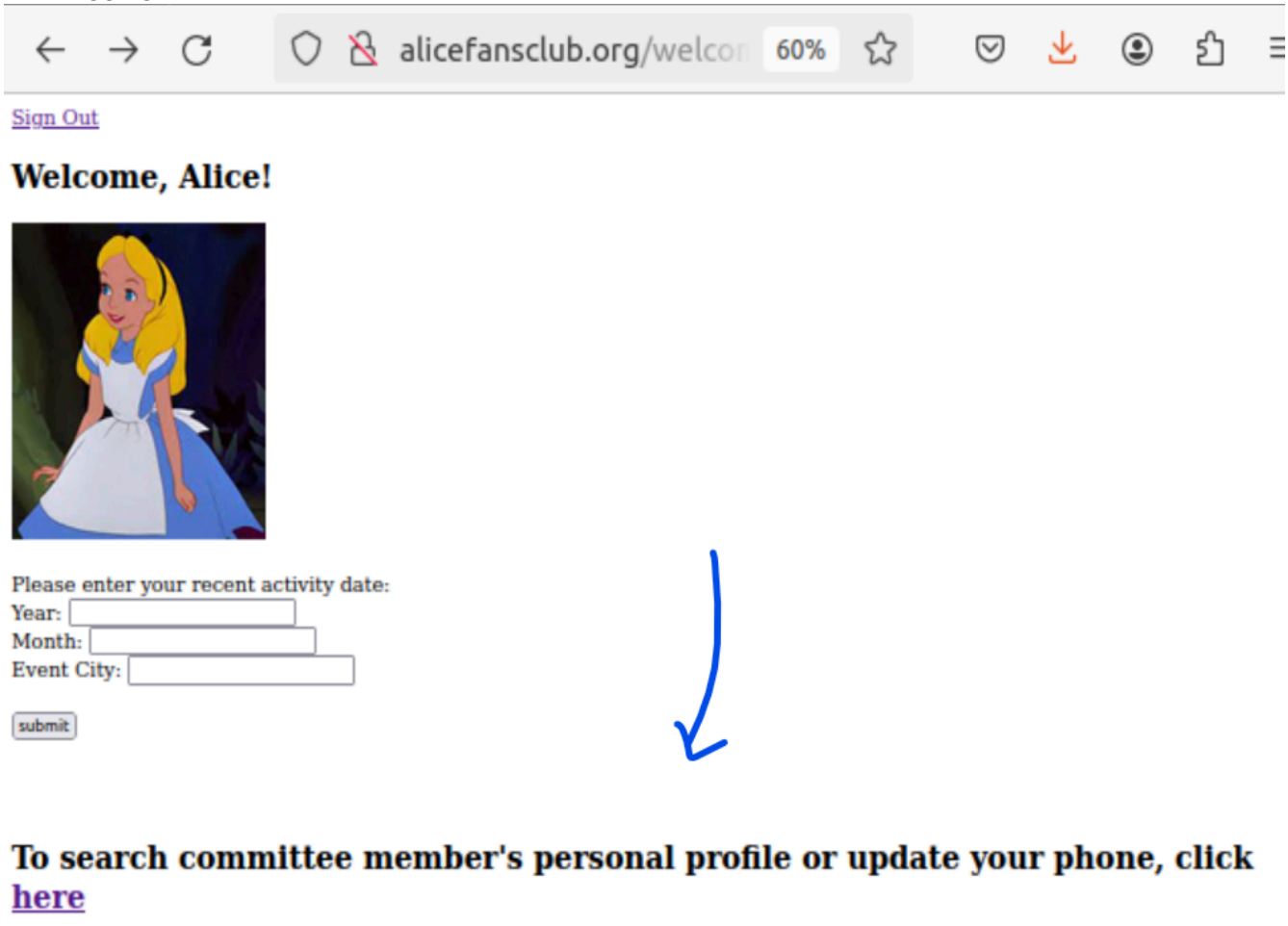


Fig. 5. *Member welcome page with link to committee personal profile at bottom.*

Alice's personal profile search page should appear as in **Fig.6**.

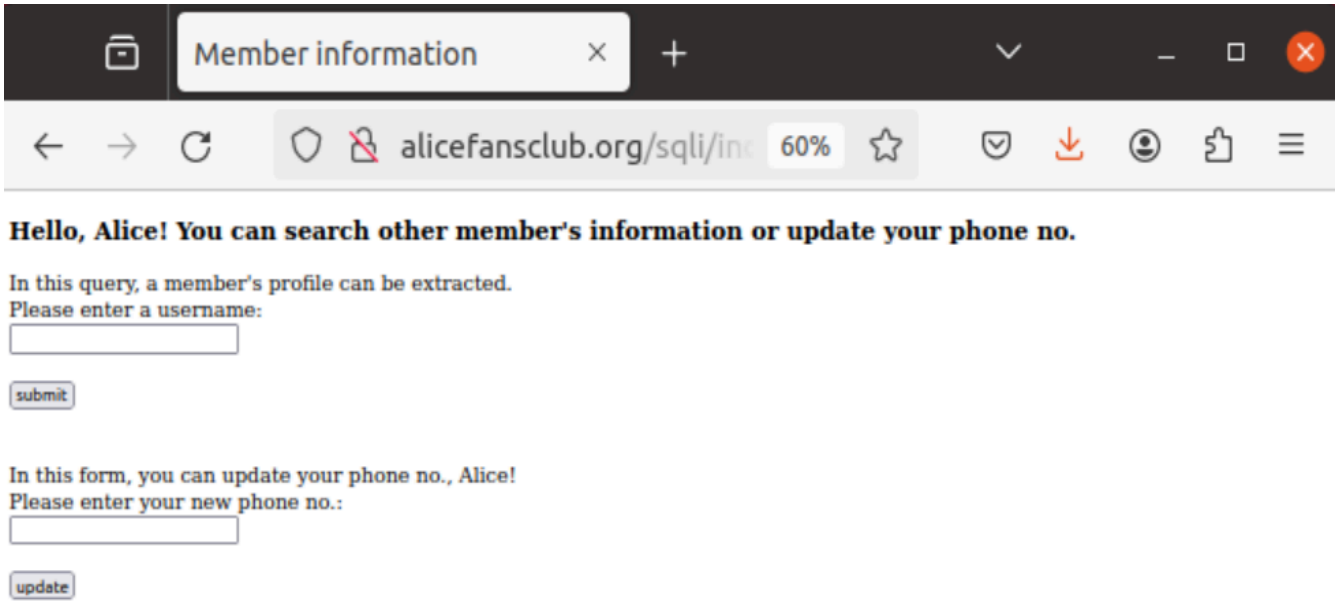


Fig. 6. *Member personal profile search page.*

When you type in a username in the textbox under "Please enter a username:" in the search page, the personal details of the member user (**title, salary and phone no.)** will be shown in the website.

For example, if you submit the form with username = "**Alice**", the information will be as shown in **Fig. 7**.

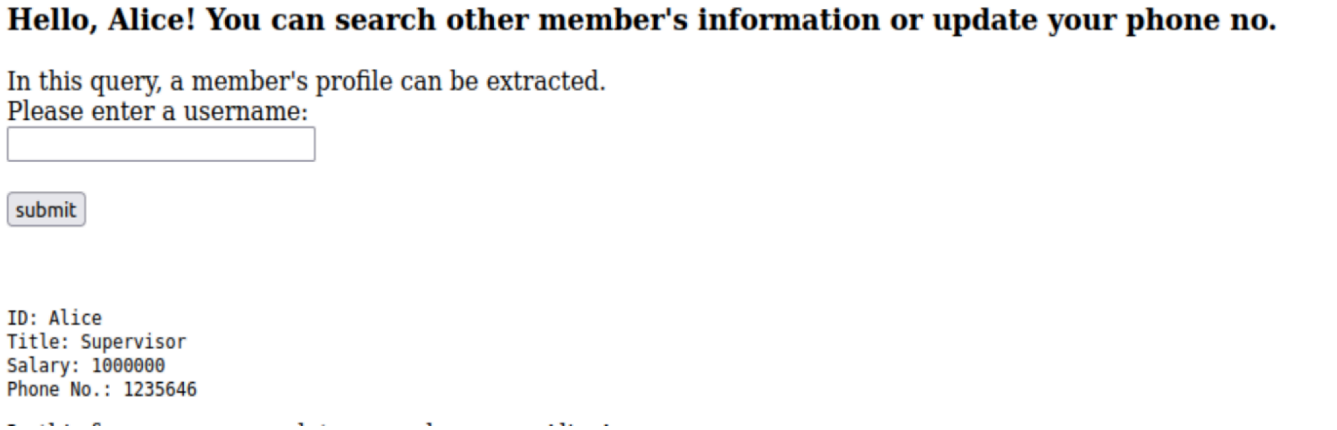


Fig. 7. *Search results for username "Alice".*

Complete the following tasks:

Task 3A (4 marks)

In this task, you should test for SQL injection vulnerabilities via user input of the query to achieve the following tasks. You should include your injection inputs and the screen captures of results in your presentation.

3A.(i) Test to:

- Find out whether the username input box in the **Fig. 7** page has an SQL injection vulnerability. What kind of SQL statement do you think is being used by the web application (Insert, Update, Select or other)?
- Try to craft a malicious input for the username input box to list information on **all** the users.

3A.(ii) Make use of the username textbox to find:

- all tables in the database
- among the possible tables, the name of the database table which likely contains user personal private information e.g. the user names, salary, and password
- list the corresponding **names** of fields (columns) in the database table you named above, and the **values** of three of the private information fields for all the users in the table

Task 3B (3 marks)

In the bottom half of the member personal profile search page (see **Fig. 6**), user **Alice** can *update* her phone no. by entering a new phone no. Your subtasks are:

3B.(i) What kind of SQL statement is being used in this box? Attempt to make use of the fields found in Task 3A to test for and exploit an SQL injection vulnerability in the phone update textbox to update some information other than phone no.

3B.(ii) Include your SQL injection malicious input and screen captures before and after the changes by using a member profile search page query, and explain your interpretation of the test results.

3B.(iii) How to prevent this type of attack?

Hints: Refer to the **SQL statement quick reference** to look for a likely SQL statement for subtask **3B.(i)** and the statement syntax to help you craft your malicious input for subtask **3B.(ii)**.

Task 4: Reflection on Invited Lecture (10 marks)

Complete the following tasks within the specified word counts below.

- **Task 4A: Reflection on invited lecture (5 marks) in no more than 250 words**:
    - Summarize the main points of the invited lecture
    - Describe one takeaway from the lecture that inspires you the most
    - Describe what the future developments in cybersecurity are likely to be
    - What advice for your career development you may consider to adopt.

- **Task 4B: Reflection on your personal experience or observation (5 marks) in no more than 250 words**:
    - Choose one cyber incident you have either experienced or heard about in the news
    - Describe and explain **how the attack worked** in the incident
    - Based on the model of “C I A A” in this unit, explain which security goal/s can be compromised by the above attack in the incident?
    - Explain a remediation to the incident.

Appendices

WARNING (Academic integrity): It is an academic requirement that your submitted work be original. Zero marks will be awarded for the whole submission if there is any evidence of plagiarism or contract cheating (i.e. paying another person to complete the assessment task). It is fine to use code or other material from various sources in your report. However, any material that you obtain from some source (e.g. website, book, paper, article) **must be cited** in the appropriate place in your report and **listed in the references section** of your report. Please also note that students must work on this assignment individually, and significant similarities between assignments will be investigated for evidence of plagiarism.

REMARK (Guidelines on Use of AI tools in the Assignment): ChatGPT or other AI tools may be used for study purposes, to learn about your tasks, and to develop your assignment. However, similar to citation requirements for other references (see “Academic Integrity” statement above), you **must include a clear declaration of all generative AI tools used** (e.g. ChatGPT, DALL-E, Grammarly, voice-to-text), **how and where you have used them**. In particular, you should be aware that output of AI tools may not be factually correct and you should therefore critically evaluate the output generated by such tools for claim accuracy and appropriateness to the tasks, using reliable sources, before incorporating such output in your assignment (e.g. an example declaration may be: ‘ChatGPT was used to generate an initial structure, then I edit this to correct factual inaccuracies, add citations to support claims’).

Where to get help

What can you get help for?

English language skills

if you don't feel confident with your English.

- Talk to English Connect: https://www.monash.edu/english-connect

Study skills

If you feel like you just don't have enough time to do everything you need to, maybe you just need a new approach

- Talk to an academic skills advisor: https://www.monash.edu/learnhq/consultations

Things are just really scary right now

Everyone needs to talk to someone at some point in their life, no judgement here.

- Talk to a counsellor: https://www.monash.edu/health/counselling/appointments
  (friendly, approachable, confidential, free)

Things in the unit don't make sense

Even if you're not quite sure what to ask about, if you're not sure you won't be alone, it's always better to ask.

- Ask in the forums or email your tutor:

  Teaching team: https://lms.monash.edu/course/view.php?id=155649&section=1

  Consultation: https://lms.monash.edu/mod/resource/view.php?id=11630825

I don't know what I need

Everyone at Monash University is here to help you. If things are tough now they won't magically get better by themselves. Even if you don't exactly know, come and talk with us and we'll figure it out. We can either help you ourselves or at least point you in the right direction.

Change log

All changes to the assignment will be listed here with the time of the change (in Malaysia time):

- **20 May 2024**: v1 of specs released.
- **24 May 2024**: v2, containing the following correction:
    - p. 11: “how attacker used” replaced by “**how the attack worked**”.